

ZAP by Checkmarx

Scanning Report

Generated with  ZAP on Thu 27 Aug 2026, at 20:10:16

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

- [About This Report](#)
 - [Report Parameters](#)
- [Summaries](#)
 - [Alert Counts by Risk and Confidence](#)
 - [Alert Counts by Site and Risk](#)
 - [Alert Counts by Alert Type](#)
 - [Insights](#)
- [Alerts](#)
 - [Risk=High, Confidence=Low \(1\)](#)
 - [Risk=Medium, Confidence=High \(1\)](#)
 - [Risk=Medium, Confidence=Medium \(2\)](#)
 - [Risk=Low, Confidence=High \(1\)](#)

- [Risk=Low, Confidence=Medium \(3\)](#)
- [Risk=Informational, Confidence=High \(1\)](#)
- [Risk=Informational, Confidence=Medium \(4\)](#)
- [Risk=Informational, Confidence=Low \(2\)](#)
- [Appendix](#)
 - [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <https://localhost>
- <http://localhost>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence			
		User Confirmed	High	Medium	Low
Risk	High	0 (0.0%)	0 (0.0%)	0 (0.0%)	1 (6.7%)
	Medium	0 (0.0%)	1 (6.7%)	2 (13.3%)	0 (0.0%)
	Low	0 (0.0%)	1 (6.7%)	3 (20.0%)	0 (0.0%)
	Informational	0 (0.0%)	1 (6.7%)	4 (26.7%)	2 (13.3%)
	Total	0 (0.0%)	3 (20.0%)	9 (60.0%)	3 (20.0%)
		Total			
		15			

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

	Risk			
	High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
https://localhost	0 (0)	1 (1)	0 (1)	0 (1)
Site http://localhost	1 (1)	2 (3)	4 (7)	7 (14)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
SQL Injection	High	1 (6.7%)
Content Security Policy (CSP) Header Not Set	Medium	2 (13.3%)
Total		15

Alert type	Risk	Count
HTTP Only Site	Medium	1 (6.7%)
Missing Anti-clickjacking Header	Medium	2 (13.3%)
Cookie No HttpOnly Flag	Low	2 (13.3%)
Cookie without SameSite Attribute	Low	2 (13.3%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	1 (6.7%)
X-Content-Type-Options Header Missing	Low	2 (13.3%)
Authentication Request Identified	Informational	1 (6.7%)
Cookie Poisoning	Informational	1 (6.7%)
Information Disclosure - Sensitive Information in URL	Informational	1 (6.7%)
Modern Web Application	Informational	2 (13.3%)
Session Management Response Identified	Informational	2 (13.3%)
User Agent Fuzzer	Informational	5 (33.3%)
User Controllable HTML Element Attribute (Potential XSS)	Informational	1 (6.7%)
Total		15

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	4
Low	Warning		ZAP warnings logged - see the zap.log file for details	8
Low	Exceeded Low		Percentage of network failures	5 %
Info	Informational	http:// / localhost	Percentage of responses with status code 2xx	31 %
Info	Informational	http:// / localhost	Percentage of responses with status code 3xx	40 %
Info	Exceeded Low	http:// / localhost	Percentage of responses with status code 4xx	26 %
Info	Informational	http:// / localhost	Percentage of responses with status code 5xx	1 %
Info	Informational	http://	Percentage of	100 %

Level	Reason	Site	Description	Statistic
	onal	/ localh ost	endpoints with content type text/ html	
Info	Informati onal	http:/ / localh ost	Percentage of endpoints with method GET	83 %
Info	Informati onal	http:/ / localh ost	Percentage of endpoints with method POST	16 %
Info	Informati onal	http:/ / localh ost	Count of total endpoints	12
Info	Informati onal	https: // localh ost	Percentage of endpoints with method GET	100 %
Info	Informati onal	https: // localh ost	Count of total endpoints	1

Alerts

Risk=High, Confidence=Low (1)

http://localhost (1)

SQL Injection (1)

▼ GET http://localhost/dvwa/vulnerabilities/sqli/?id=%27&Submit=Submit

Alert tags

- POLICY_SEQUENCE =
- [OWASP_2021_A03](#)
- [PCI_DSS](#)
- [CWE-89](#)
- POLICY_QA_CICD =
- POLICY_DEV_CICD =
- [OWASP_2025_A05](#)
- [WSTG-v42-INPV-05](#)
- POLICY_API =
- POLICY_DEV_FULL =
- POLICY_QA_STD =
- POLICY_QA_FULL =
- POLICY_PENTEST =
- [HIPAA](#)
- [OWASP_2017_A01](#)
- [API_2023_API10](#)
- POLICY_DEV_STD =

Alert description

SQL injection may be possible.

Request

▼ Request line and header section (480 bytes)

```
GET http://localhost/dvwa/vulnerabilities/sqli/?id=%27&Submit=Submit HTTP/1.1
host: localhost
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0 Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Connection: keep-alive
```


	Referer: http://localhost/dvwa/vulnerabilities/sqli/ Cookie: PHPSESSID=23b701d2dfd9340a67cbeeeacf8e598d; security=low Upgrade-Insecure-Requests: 1 Priority: u=0, i ▼ Request body (0 bytes)
Response	▼ Status line and header section (295 bytes) HTTP/1.0 500 Internal Server Error Date: Thu, 27 Aug 2026 14:24:58 GMT Server: Apache/2.4.68 (Debian) Expires: Thu, 19 Nov 1981 08:52:00 GMT Cache-Control: no-store, no-cache, must-revalidate Pragma: no-cache Content-Length: 0 Connection: close Content-Type: text/html; charset=UTF-8 ▼ Response body (0 bytes)
Parameter	id
Attack	'
Evidence	HTTP/1.0 500 Internal Server Error
Solution	Do not trust client side input, even if

there is client side validation in place.

In general, type check all data on the server side.

If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?'

If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries.

If database Stored Procedures can be used, use them.

Do **not** concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality!

Do not create dynamic SQL queries using simple string concatenation.

Escape all data received from the client.

Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input.

Apply the principle of least privilege by using the least privileged database user possible.

In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact.

Grant the minimum database access that is necessary for the application.

Risk=Medium, Confidence=High (1)

[http://localhost \(1\)](#)

Content Security Policy (CSP) Header Not Set (1)

▼ GET <http://localhost/dvwa/login.php>

Alert tags

- [OWASP_2021_A05](#)
- POLICY_QA_STD =
- POLICY_PENTEST =
- [SYSTEMIC](#)
- [CWE-693](#)
- [OWASP_2017_A06](#)
- [OWASP_2025_A02](#)

Alert description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Request**▼ Request line and header section (526 bytes)**

```
GET http://localhost/dvwa/
login.php HTTP/1.1
host: localhost
User-Agent: Mozilla/5.0 (X11;
Linux x86_64; rv:140.0)
Gecko/20100101 Firefox/140.0
Accept: text/html,application/
xhtml+xml,application/
xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Referer: http://localhost/dvwa/
vulnerabilities/sqli/index.php?
id=1&Submit=Submit&user_token=4
54a347707fa0a30aef42703379eb741
Connection: keep-alive
Cookie:
PHPSESSID=3925bc95eec611f28402c
6ed528d0713;
security=impossible
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

▼ Request body (0 bytes)**Response****▼ Status line and header section (327 bytes)**

```
HTTP/1.1 200 OK
Date: Thu, 27 Aug 2026
14:24:05 GMT
Server: Apache/2.4.68 (Debian)
Expires: Tue, 23 Jun 2009
12:00:00 GMT
Cache-Control: no-cache, must-
revalidate
Pragma: no-cache
Vary: Accept-Encoding
```

```
Content-Length: 1342
Keep-Alive: timeout=5, max=99
Connection: Keep-Alive
Content-Type: text/
html; charset=utf-8
```

▼ Response body (1342 bytes)

```
<!DOCTYPE html>
```

```
<html lang="en-GB">
```

```
    <head>
```

```
        <meta http-
equiv="Content-Type"
content="text/html;
charset=UTF-8" />
```

```
        <title>Login
:: Damn Vulnerable Web
Application (DVWA)</title>
```

```
        <link
rel="stylesheet" type="text/
css" href="dvwa/css/login.css"
/>
```

```
    </head>
```

```
    <body>
```

```
        <div id="wrapper">
```

```
            <div id="header">
```

```
                <br />
```

```
                <p></p>
```

```
<br />

</div> <!--<div
id="header">-->

<div id="content">

    <form
action="login.php"
method="post">

        <fieldset>

                                <label
for="user">Username</label>
<input type="text"
class="loginInput" size="20"
name="username"><br />

                                <label
for="pass">Password</label>
<input type="password"
class="loginInput"
autocomplete="off" size="20"
name="password"><br />

                                <br />

                                <p
class="submit"><input
type="submit" value="Login"
name="Login"></p>

        </fieldset>

        <input type='hidden'
name='user_token'
value='6749170db073167ef087b1fc
1ef1c471' />

    </form>
```

```
<br />

<br />
<br />
<br />
<br />
<br />
<br />
<br />

</div> <!--<div
id="content">-->

<div id="footer">

<p><a href="https://
github.com/digininja/DVWA/"
target="_blank">Damn
Vulnerable Web Application
(DVWA)</a></p>

</div> <!--<div
id="footer"> -->

</div> <!--<div
id="wrapper"> -->

</body>

</html>
```

Solution

Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Risk=Medium, Confidence=Medium (2)**<https://localhost> (1)****HTTP Only Site (1)**

► GET http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit&user_token=f36b318e7029ccac61c95d325914560c

<http://localhost> (1)**Missing Anti-clickjacking Header (1)**

► GET <http://localhost/dvwa/login.php>

Risk=Low, Confidence=High (1)**<http://localhost> (1)****Server Leaks Version Information via "Server" HTTP Response Header Field (1)**

► GET http://localhost/dvwa/vulnerabilities/sqli/index.php?id=3&Submit=Submit&user_token=aa19171b13f6ad65589d5310a1054744

Risk=Low, Confidence=Medium (3)**<http://localhost> (3)****Cookie No HttpOnly Flag (1)**

► POST <http://localhost/dvwa/security.php>

Cookie without SameSite Attribute (1)

- ▶ POST http://localhost/dvwa/security.php

X-Content-Type-Options Header Missing (1)

- ▶ GET http://localhost/dvwa/login.php

Risk=Informational, Confidence=High (1)

http://localhost (1)

Authentication Request Identified (1)

- ▶ POST http://localhost/dvwa/login.php

Risk=Informational, Confidence=Medium (4)

http://localhost (4)

Information Disclosure - Sensitive Information in URL (1)

- ▶ GET http://localhost/dvwa/vulnerabilities/sqli/index.php?id=3&Submit=Submit&user_token=aa19171b13f6ad65589d5310a1054744

Modern Web Application (1)

- ▶ GET http://localhost/dvwa/index.php

Session Management Response Identified (1)

- ▶ POST http://localhost/dvwa/login.php

User Agent Fuzzer (1)

- ▶ GET http://localhost/dvwa/vulnerabilities/sqli/?

```
id=1&Submit=Submit&user_token=f36b318e7029ccac61c95d325914560c
```

Risk=Informational, Confidence=Low (2)

<http://localhost> (2)

Cookie Poisoning (1)

- ▶ POST <http://localhost/dvwa/security.php>

User Controllable HTML Element Attribute (Potential XSS) (1)

- ▶ GET <http://localhost/dvwa/vulnerabilities/sqli/?id=2&Submit=Submit>

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

SQL Injection

Source	raised by an active scanner (SQL Injection)
CWE ID	89
WASC ID	19
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

HTTP Only Site

Source	raised by an active scanner (HTTP Only Site)
CWE ID	311
WASC ID	4
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html ▪ https://letsencrypt.org/

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Cookie No HttpOnly Flag

Source	raised by a passive scanner (Cookie No HttpOnly Flag)
CWE ID	1004
WASC ID	13
Reference	▪ https://owasp.org/www-community/HttpOnly

Cookie without SameSite Attribute

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275
WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server Response Header)
CWE ID	497
WASC ID	13
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens ▪ https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15

Reference

- [https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941\(v=vs.85\)](https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85))
- <https://owasp.org/www-community/Security-Headers>

Authentication Request Identified**Source**

raised by a passive scanner ([Authentication Request Identified](#))

Reference

- <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/>

Cookie Poisoning**Source**

raised by a passive scanner ([Cookie Poisoning](#))

CWE ID

[565](#)

WASC ID

20

Reference

- https://en.wikipedia.org/wiki/HTTP_cookie
- <https://cwe.mitre.org/data/definitions/565.html>

Information Disclosure - Sensitive Information in URL**Source**

raised by a passive scanner ([Information Disclosure - Sensitive Information in URL](#))

CWE ID

[598](#)

WASC ID

13

Modern Web Application

Source raised by a passive scanner ([Modern Web Application](#))

Session Management Response Identified

Source raised by a passive scanner ([Session Management Response Identified](#))

Reference

- <https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/>

User Agent Fuzzer

Source raised by an active scanner ([User Agent Fuzzer](#))

Reference

- <https://owasp.org/wstg>

User Controllable HTML Element Attribute (Potential XSS)

Source raised by a passive scanner ([User Controllable HTML Element Attribute \(Potential XSS\)](#))

CWE ID [20](#)

WASC ID 20

Reference

- https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html